

Dquez Carr  
Reading Assignment  
MCY 650  
September, 2024

1. What are the 10 most critical web app security flaws (based on OWASP top 10)? Please do not list just these 10 flaw names. Instead, summarize these using a few of your own sentences along with these 10 flaw names.

As of 2021 the OWASP top 10 are as follows.

**A01:2021-Broken Access Control** occurs when an application does not appropriately limit user access to resources or functionalities, consequently granting unauthorized users access and enabling them to carry out actions that they shouldn't be able to.

**A02:2021-Cryptographic Failures** occur when sensitive information may be exposed, compromised, or improperly managed as a result of insecure or improper encryption techniques, leaving it open to manipulation or interception.

**A03:2021-Injection** occurs when an attacker inserts malicious code (like SQL, NoSQL, or command injections) into an application, which the system then runs, potentially causing unauthorized actions or data breaches.

**A04:2021-Insecure Design** Attackers may be able to take advantage of security flaws in the application's architecture or design, which are frequently the consequence of insufficient security considerations during the design stage.

**A05:2021-Security Misconfiguration** results from incorrect or incomplete security setting configurations, which can be exploited to create default credentials or overly permissive settings.

**A06:2021-Vulnerable and Outdated Components** occur when using out-of-date or known vulnerable libraries, frameworks, or other software components leaves an application open to attack if those flaws are used against it.

**A07:2021-Identification and Authentication Failures** Data breaches are more likely when sensitive areas of an application are accessed by unauthorized parties due to inefficient authentication procedures or improper management of user identities.

**A08:2021-Software and Data Integrity Failures** occur when an application fails to check the accuracy of the software or data, making it possible for harmful or unauthorized changes to take place undetected.

**A09:2021-Security Logging and Monitoring Failures** It might be challenging to identify security incidents or breaches due to ineffective logging and monitoring procedures, which makes it challenging to react quickly to attacks.

**A10:2021-Server-Side Request Forgery** An attacker can exploit this vulnerability by tricking the server into sending unexpected requests to external or internal systems, which could result in data exposure or unauthorized access.

2. EC-Council defines 6 different stages in web server attack methodology. What are these?  
Web server information gathering, web server footprinting, website mirroring, vulnerability scanning, session hijacking, and web server password cracking.

3. What are the top 3 web servers being used today in terms of market share?  
Apache HTTP Server, Microsoft Internet Information Services, and Nginx

4. What makes Nginx a high-performance HTTP server?  
High-performance HTTP server **Nginx** is known for its event-driven, asynchronous architecture, which enables it to manage thousands of concurrent connections while consuming little in the way of resources. Serving static content rapidly and effectively is one of its strong points. It also has strong functions as a load balancer and reverse proxy, maximizing resource usage and speeding up response times. Nginx can be customized to meet a variety of needs thanks to its support for contemporary protocols like HTTP/2, effective caching techniques, and flexible configuration options. Because of its robust security features and vibrant community, it is regarded as the best option for web applications with heavy traffic.

5. What is the difference between XML and HTML?  
**XML** is a data transport and storing language that permits users to create unique tags and maintains stringent validation and data structure requirements. **HTML** uses a more flexible syntax and a fixed set of predefined tags to display content in web browsers. HTML combines content with formatting and is unique to web development, while XML separates presentation from content and is highly interoperable for data interchange across platforms. All things considered, HTML prioritizes layout and presentation, while XML stresses data structure and meaning.

6. When you type some text in google's search box, your browser sends a HTTP GET request to google. Why GET, not POST method of HTTP in this case?  
**GET** because it is made for safe, independent data retrieval, supports URL-based queries, permits caching, and makes search parameters visible.

7. What is the use of the HEAD method of HTTP?  
The HEAD method in HTTP is used to retrieve only the headers of a resource without downloading its content. This makes it possible for clients to obtain metadata, which is helpful for determining the availability and status of a resource without transferring the full body, such as content type, length, and modification date. It supports efficient caching management through validation header checking, link testing, and performance optimization through bandwidth reduction. In general, the HEAD approach is a useful tool for quickly and effectively gathering resource information.

8. What is directory traversal attack? Please describe and show an example.

**A directory traversal or path traversal attack** is a type of web security vulnerability that allows an attacker to access files and directories that are stored outside the intended directory of a web application. Attackers can use this vulnerability to obtain unauthorized access to sensitive files, including configuration files, password files, and any other file on the server, by changing file paths.

**`http://www.example.com/../../../../etc/passwd`**

This sends HTTP requests asking the server to drop back to the root directory and give access to the password folder.

9. What is XSS?

XSS is a web security vulnerability that enables attackers to inject malicious scripts into web pages viewed by other users, potentially leading to data theft, session hijacking, and malware distribution. There exist three primary forms of cross-site scripting (XSS): stored XSS, in which the script is saved on the server permanently; reflected XSS, in which the script is immediately reflected off the server; and DOM-based XSS, which takes place within the client-side JavaScript. Developers should use Secure cookie flags, HTTPOnly, Content Security Policies (CSP), encode output data, validate and sanitize user inputs, and use HTTPOnly to reduce the risk of cross-site scripting attacks.

10. What is CSRF?

CSRF is a web security vulnerability that allows attackers to trick authenticated users into unknowingly submitting requests to a web application, potentially leading to unauthorized actions like transferring funds or changing account settings. This happens when a malicious website creates requests using the user's authentication cookies in order to take advantage of the user's active session. Developers can use the 'SameSite' cookie attribute, validate the 'Referer' header, use anti-CSRF tokens, and ask users to confirm sensitive actions in order to prevent CSRF attacks.